YIFEI SUN

Staff Software Engineer · IAM, Identity Federation & Secure Distributed Systems · 13 Years

(617) 922-4823
sun1fei@gmail.com
linkedin.com/in/yifei-sun-a789861b

SUMMARY

Staff-level engineer with 13 years building identity infrastructure, secure distributed systems, and cloud-native platforms at scale. Architected and shipped production IAM platforms — designed Keycloak-based SSO with OAuth 2.0 and SAML identity federation, built custom token validation and RBAC enforcement plugins at the API gateway layer (Kong, Nginx), and deployed secure service mesh (Linkerd + mTLS on Kubernetes) for service-to-service trust. Led multi-quarter technical strategy for a high-traffic API platform serving millions of daily requests (p99 250ms→50ms, 99.9% availability), driving architecture standards and engineering excellence across 10+ teams via RFCs and design docs. Combines deep hands-on security engineering with cross-organizational technical leadership in document-driven, distributed team environments. Daily user of HashiCorp Terraform for infrastructure automation.

LEADERSHIP HIGHLIGHTS

- Built production IAM platform: Keycloak SSO (OAuth 2.0, SAML), identity federation across 3 platforms, RBAC enforcement at API gateway
- Deployed secure service mesh (Linkerd + Kong on K8s) with mTLS, custom auth plugins (Python), rate limiting, and traffic management
- Led multi-quarter API platform redesign: p99 5× reduction, 99.9% availability, cross-team strategy spanning 10+ teams and 3 departments
- Drove technical strategy and architecture standards via RFCs, design docs, and ADRs — document-based async collaboration across distributed teams

Technologies: IAM & Security: OAuth 2.0, SAML, Keycloak, JWT/token validation, RBAC/ABAC, SCIM-compatible provisioning, Kong, Nginx · **Languages:** Java (13 years), Python, Node.js/TypeScript, Golang (familiar) · **Infrastructure:** Terraform, Ansible, AWS (ECS, EKS, SQS, SNS, S3, RDS, DynamoDB) · Kubernetes, Docker, Linkerd (service mesh), Kafka, Redis, PostgreSQL, Cassandra · REST API, gRPC, GraphQL · Event-Driven, CQRS · Datadog, Grafana, Distributed Tracing · CI/CD

EXPERIENCE

CarGurus — Principal Software Engineer / Technical Lead

Oct 2019 – Present

Multi-Quarter API Platform Strategy — Secure Microservices at Scale

- Defined and drove the multi-quarter technical strategy for redesigning CarGurus' highest-traffic API (~8,000 rpm, millions of daily impressions), leading 3 principal/senior engineers and aligning 10+ teams across 3 departments — from vision through execution.
- Architected orchestration service consolidating 12 downstream integrations into 5 well-defined services with per-service authentication, authorization boundaries, circuit breaking, fault isolation, and idempotent retry.
- Built automated correctness verification infrastructure comparing new vs. legacy responses at 50% production traffic, enabling safe, data-driven rollout decisions with zero integrity regressions.

p99: 250 ms → 50 ms (5×) **Availability: 98% → 99.9%** **Deploy: 1 hr → 3 min** (20×)

Cross-Org Architecture Standards & Engineering Excellence

- Established reusable patterns for API security, observability, caching, and distributed orchestration adopted across multiple teams; authored design docs, RFCs, and architecture decision records in a document-driven async culture.
- Led 10+ engineering training sessions. Mentored senior engineers on secure system design, cross-team strategy, and path to Principal-level scope — force-multiplying organizational capability.

Event-Driven Platform & GraphQL Federation

- Led backend platform design using event-driven architecture (SQS/SNS, Kafka) with Terraform-managed AWS infrastructure and IAM-based access controls per service boundary.
- Designed Netflix DGS subgraph for federated GraphQL gateway with per-consumer authorization, exposing data to frontend, backend, and AI consumers through a unified, access-controlled graph.

Applause — Senior Software Engineer / Technical Lead

Oct 2017 – Oct 2019

IAM Platform — Identity Federation, Token Auth & Secure Gateway

- Architected and deployed a production IAM platform: migrated legacy auth to Keycloak-based SSO with OAuth 2.0 and SAML identity federation, unifying authentication and authorization across internal systems, an enterprise partner platform, and a large external

community with role-based access control.

- Built custom token validation and RBAC enforcement plugins for Kong API gateway in Python — per-request JWT validation against Keycloak, token refresh handling, session management, and fine-grained permission checks at the gateway layer before requests reach backend services.
- Deployed service mesh (Linkerd on Kubernetes) with mTLS for secure service-to-service communication and zero-trust networking. Performed Glassfish-to-modern-runtime migration with JVM performance tuning.
- Coordinated migration of multiple Java and Node.js services behind the new auth gateway with minimal downtime, aligning 4 teams to ensure consistent identity and access management posture across the entire platform.

Event Sourcing & Microservices Architecture

- Drove design and prototyping of microservice architecture based on event sourcing and CQRS; defined foundational security isolation and data access patterns for services, events, and read/write models adopted by new domains.

Toast Inc. — Senior Software Engineer

Sep 2014 – Oct 2017

Core Platform Services & API Gateway Security

- Among the earliest engineers during hypergrowth; built core platform services end-to-end (Order Service, Labor Service, REST APIs) with authentication, authorization, and input validation at every service boundary.
- Built a custom API gateway in Nginx with Lua scripting for rate limiting, request authentication, traffic routing, and abuse prevention — the first security enforcement layer for all external API traffic.
- Set up the initial AWS environment using Ansible — provisioned infrastructure, deployment pipelines, IAM policies, and monitoring before a dedicated DevOps or security team existed.

Secure Third-Party Integrations

- Led API integrations with key partners (workforce management) with authenticated bidirectional sync, schema validation, and access control. Partnered cross-functionally with PMs, sales, and support.

The MathWorks Inc. — Software Engineer II

Jul 2013 – Aug 2014

Developed internal engineering tools (Java backend) for MATLAB/Simulink workflows. Improved backend automation systems for build/test reliability and developer productivity.

EDUCATION

M.S. in Electrical and Computer Engineering — Northeastern University, Boston 2010 – 2013

B.S. in Information Science — Beijing University of Aeronautics and Astronautics 2006 – 2010